

Figure 1 - The login screen



Figure 2 - The Samurai WTF desktop

various components of the application? At this stage, you map these, and understand the workings of the Web application. You begin to understand how the system works, as a whole. This is highly useful to identify possible vulnerabilities, loopholes and exploits.

Stage 3: Discovery

This is where you discover the vulnerabilities. There are two types of discoveries: client-side and server-side. Client-side discoveries include breaking open (or decompiling) Flash, Java and the AJAX components of the Web application on the client end. Server-side discoveries are vulnerabilities like SQL injection, session exploits, information leaks, username harvesting, command injections, etc.

Stage 4: Exploitation

This is the fun part. Based on the previous stages, you actually exploit the Web application to test its resilience. At this point, you begin to understand the actual working and impact of the loopholes.

The four stages are iterative in nature, and can go on continuously for a Web application—yielding priceless data to help you understand the weaknesses of the system. The ultimate goal of this is, of course, to plug these holes, and

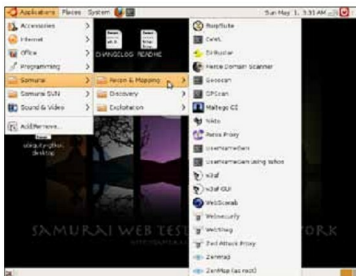


Figure 3 - Tools: Reconnaissance and Mapping



Figure 4 - Tools: Discovery

make the system more secure from real attackers. Compare this to running a fire drill in your building, or simulating a bank robbery to ensure that the bank's security is robust.

Enter Samurai WTF

Okay, I know the acronym WTF has a tendency to invoke the giggles, but it stands for Web-Testing Framework, and not what you thought initially. (Get your mind out of the gutter.) Samurai is a live Linux distribution packed to the brim with the best open source pen-testing tools for all the four stages listed above. What's more, it has a pre-configured wiki that acts as a central store of information during testing.

Getting started with Samurai

Like any other live distro, download the ISO from the website (the links are at the end of the article) and burn it to a disc, or use a virtualisation tool like VirtualBox to test it. Once the disc boots, you will be greeted with a boot prompt that looks like many other Live CDs. Just type *live* at the *boot*: prompt to start the booting process. After the boot-up is complete, you will be greeted by